

Patient Management Portal - Data Model & Entity Relationship

Confidential - Internal Use Only

Version 1.0

1. Core Entities

Entity: Patient - Fields: patient_id (UUID PK), mrn (VARCHAR 20 UNIQUE, Medical Record Number), first_name (VARCHAR 100, encrypted), last_name (VARCHAR 100, encrypted), date_of_birth (DATE, encrypted), email (VARCHAR 255, encrypted), phone (VARCHAR 20, encrypted), address_id (UUID FK), insurance_id (UUID FK), created_at (TIMESTAMP). Note: All PII fields encrypted with AES-256 per HIPAA.

Entity: Provider - Fields: provider_id (UUID PK), npi (VARCHAR 10 UNIQUE, National Provider ID), first_name (VARCHAR 100), last_name (VARCHAR 100), specialty (VARCHAR 100), department (VARCHAR 100), license_state (CHAR 2), active (BOOLEAN DEFAULT true).

Entity: Appointment - Fields: appointment_id (UUID PK), patient_id (UUID FK), provider_id (UUID FK), appointment_datetime (TIMESTAMPTZ), duration_minutes (SMALLINT DEFAULT 30), type (ENUM: in_person, telehealth, phone), status (ENUM: scheduled, checked_in, in_progress, completed, no_show, cancelled), location_id (UUID FK NULL), zoom_meeting_id (VARCHAR 50 NULL), created_at (TIMESTAMP).

Entity: ClinicalNote - Fields: note_id (UUID PK), appointment_id (UUID FK), provider_id (UUID FK), subjective (TEXT, encrypted), objective (TEXT, encrypted), assessment (TEXT, encrypted), plan (TEXT, encrypted), icd10_codes (JSONB), cpt_codes (JSONB), signed_at (TIMESTAMP NULL). Note: SOAP note format.

Entity: Prescription - Fields: prescription_id (UUID PK), patient_id (UUID FK), provider_id (UUID FK), medication_name (VARCHAR 255), rxnorm_code (VARCHAR 20), dosage (VARCHAR 100), frequency (VARCHAR 100), quantity (INTEGER), refills_authorized (SMALLINT), refills_remaining (SMALLINT), pharmacy_ncdpd_id (VARCHAR 10), status (ENUM: active, discontinued, expired), prescribed_at (TIMESTAMP).

Entity: InsurancePlan - Fields: insurance_id (UUID PK), patient_id (UUID FK), payer_name (VARCHAR 255), payer_id (VARCHAR 20), group_number (VARCHAR 50), member_id (VARCHAR 50, encrypted), plan_type (ENUM: primary, secondary), copay_amount (DECIMAL 8,2), deductible_met (DECIMAL 10,2), deductible_total (DECIMAL 10,2), verified_at (TIMESTAMP NULL).

Entity: LabResult - Fields: result_id (UUID PK), patient_id (UUID FK), ordering_provider_id (UUID FK), test_name (VARCHAR 255), loinc_code (VARCHAR 20), result_value (VARCHAR 50), unit (VARCHAR 20), reference_range_low (DECIMAL 10,4 NULL), reference_range_high (DECIMAL 10,4 NULL), status (ENUM: pending, final, amended), result_datetime (TIMESTAMP).

2. Relationships

Patient 1:N Appointment - A patient can have many appointments over time.

Provider 1:N Appointment - A provider has many patient appointments.

Appointment 1:1 ClinicalNote - Each completed appointment has one clinical note.

Patient 1:N Prescription - A patient has an ongoing medication list.

Provider 1:N Prescription - A provider writes many prescriptions.

Patient 1:N InsurancePlan - A patient can have primary and secondary insurance.

Patient 1:N LabResult - A patient has many lab results over time.

3. PHI Data Protection Rules

REQ-HCP-073: All PHI (Protected Health Information) fields must be encrypted at rest using AES-256 with AWS KMS-managed keys.

REQ-HCP-074: PHI access requires role-based authorization. Only 'care_team' role can view

clinical notes. 'patient' role can view own records only.

REQ-HCP-075: All PHI access events must be logged to an immutable audit table: user_id, resource_type, resource_id, action (read/write), timestamp, ip_address.

REQ-HCP-076: Patient data deletion requests (HIPAA right of access) must be processed within 30 days. Minimum retention period: 6 years for medical records per state law.

REQ-HCP-077: De-identified dataset generation for research uses Safe Harbor method (removal of 18 identifiers defined by HIPAA).

4. Data Backup & Recovery

REQ-HCP-078: Azure SQL point-in-time restore with 35-day retention. Geo-replicated to paired Azure region.

REQ-HCP-079: Daily full backup at 02:00 UTC with transaction log backups every 5 minutes. Backup encryption mandatory.

REQ-HCP-080: Annual disaster recovery test with full data restore validation. RTO: 4 hours, RPO: 5 minutes.